

FROM PASSWORDS TO PASSKEYS

An interactive guide to authentication, phishing, MFA and WebAuthn

Name: _____ zID: _____

Teach Something · beginner audience · maximum 5 minutes

INTERACTIVE SECURITY ENGINEERING GUIDE

See the system behind the sign-in.

Explore replay, real-time phishing, MFA trade-offs and origin-bound passkeys through safe conceptual activities.

Start Form A

No real usernames, passwords, MFA codes or biometrics are requested.

CLAIM

Identity: which account?



A login fails in three different places

The learning sequence names the boundary before it compares the technology.

IDENTIFY

Which account is claimed?

LO-01

ANALYSE

How can proof be replayed or relayed?

LO-02-04

EXPLAIN

Why does RP-bound proof resist phishing?

LO-05-06

Aim

A beginner should diagnose the failed layer, choose a control that changes the attack path, and state residual risk.

One safe journey links four security decisions

Versioned, device-local and designed not to collect credentials.

A/ AuthLab

LearnPhishingPasskeysResults

Device-local - v2.0.0

INTERACTIVE SECURITY ENGINEERING GUIDE

See the system behind the sign-in.

Explore replay, real-time phishing, MFA trade-offs and origin-bound passkeys through safe conceptual activities.

Start Form A

No real usernames, passwords, MFA codes or biometrics are requested.

CLAIM

Identity: which account?

↓

PROOF

Authentication: what evidence?

↓

DECISION

Authorisation: which action?

protocol + people + recovery

DATA MINIMISATION

Your learning record stays on this device

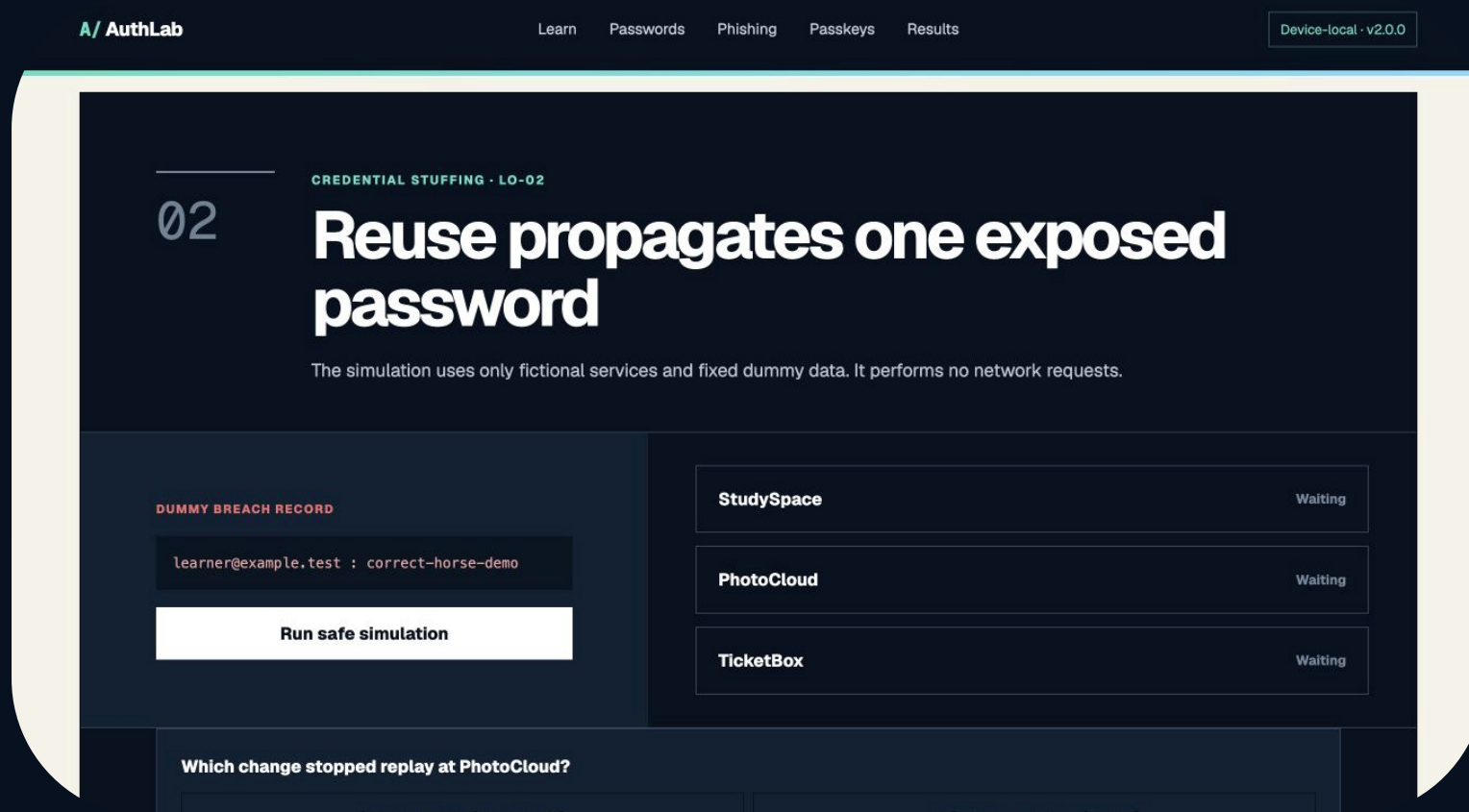
- Random de-identified session code; no name, email, zID, IP address or fingerprint.
- Local storage expires after 30 days and can be deleted at any time.
- Exports omit exact timestamps and round duration to five-minute intervals.
- Do not enter personal information in optional feedback.

- 01Separate claim, proof and permission
- 02Trace replay with fictional data
- 03Inspect domain, context and route
- 04Compare MFA with RP-bound passkeys

OUTPUTForm A/B items · 4 scenarios · confidence · de-identified export

A strong reused password is still replayable proof

Fixed fictional data shows why reuse—not complexity alone—propagates a breach.



1

Exposure

Dummy pair only

2

Automated replay

Fixed local simulation

3

Cross-service acceptance

Reuse enables takeover

Control reuse and replay, not only length.

A live phishing proxy can relay passwords and TOTP

Learners inspect the registered domain, request context and a trusted route.

A/ AuthLab Learn Passwords Phishing Passkeys Results Device-local · v2.0.0

PHISHING AND IMPERSONATION · LO-03

03 Verifier evidence beats copied pixels

Assume the attacker can build a polished real-time phishing site and relay passwords or OTPs.

PH-01 · FROM
IT Service Desk <support@example.edu>

Security key registration is available

<https://accounts.example.edu/security-keys>

Legitimate **Phishing**

Correct decision. The registered domain is example.edu and the route is plausible.

PH-02 · FROM
Campus Account Team <urgent@account-notice.example.net>

Your mailbox closes in 20 minutes

<https://example.edu.verify-login.example.net/session>

Legitimate **Phishing**

Correct decision. The registered domain is example.net; example.edu is only a subdomain label.

DECISION RULE

**Inspect origin.
Verify context.
Use a trusted route.
Report safely.**

Why this matters

TOTP is short-lived, not origin-bound. Passkeys change which verifier can receive valid proof.

A passkey signs a fresh challenge for one relying party

Private-key material stays protected; a look-alike origin cannot get valid proof for the legitimate RP.

A/ AuthLab

LearnPhishingPasskeysResults

Device-local - v2.0.0

monthly password rotation

REQUIRED CHECKPOINT

Checkpoint: finish the conceptual flow and identify origin/RP binding.

Module completed

▼ Optional real browser WebAuthn API demonstration

This is not a production login system

- A test credential may be created on this device for this origin.
- The browser/authenticator performs local user verification; the website does not receive biometric data.
- No production server persists a challenge or verifies the assertion signature.
- Nothing is required for module completion, and cancellation is safe.
- Syncable passkeys may synchronise protected key material through a platform ecosystem.

No API operation has been requested. The conceptual activity above is the default.

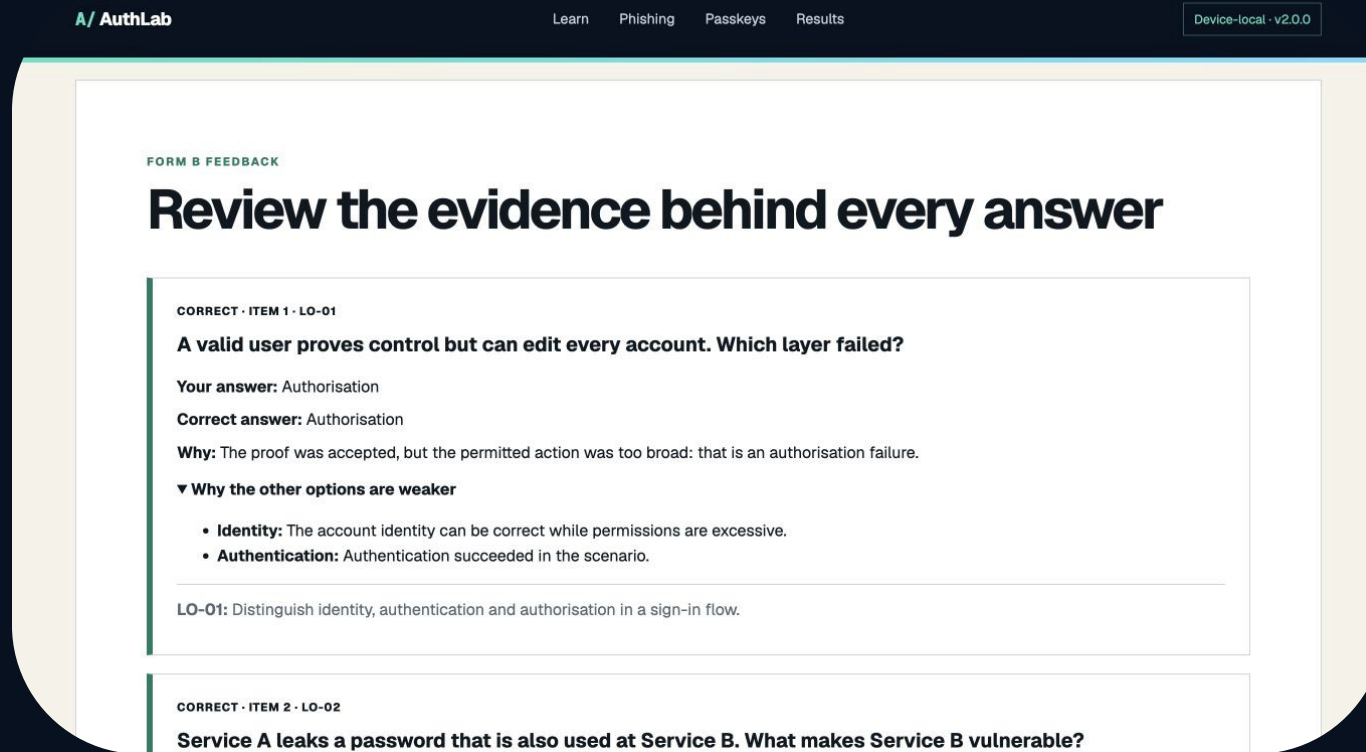
MECHANISM	PROOF	ORIGIN-BOUND
PASSWORD	replayable	NO
TOTP	short-lived	NO
PASSKEY	signed challenge	YES

Residual risk remains

Device compromise · recovery · server design · excessive authorisation

The engineering works; learning is still unmeasured

Technical checks and human learning evidence are kept separate.



TESTS

PASS

Final source and build checks

PATH

6 → 5

Deliberate developer path

HUMANS

0

No participant records supplied

Next: run the consented Form A/B protocol and report every outcome, including zero or negative change.

Change the proof, then test the teaching.

01 Diagnose

Separate identity, authentication
and authorisation.

02 Design

Control replay and relay; bind
proof to the verifier.

03 Verify

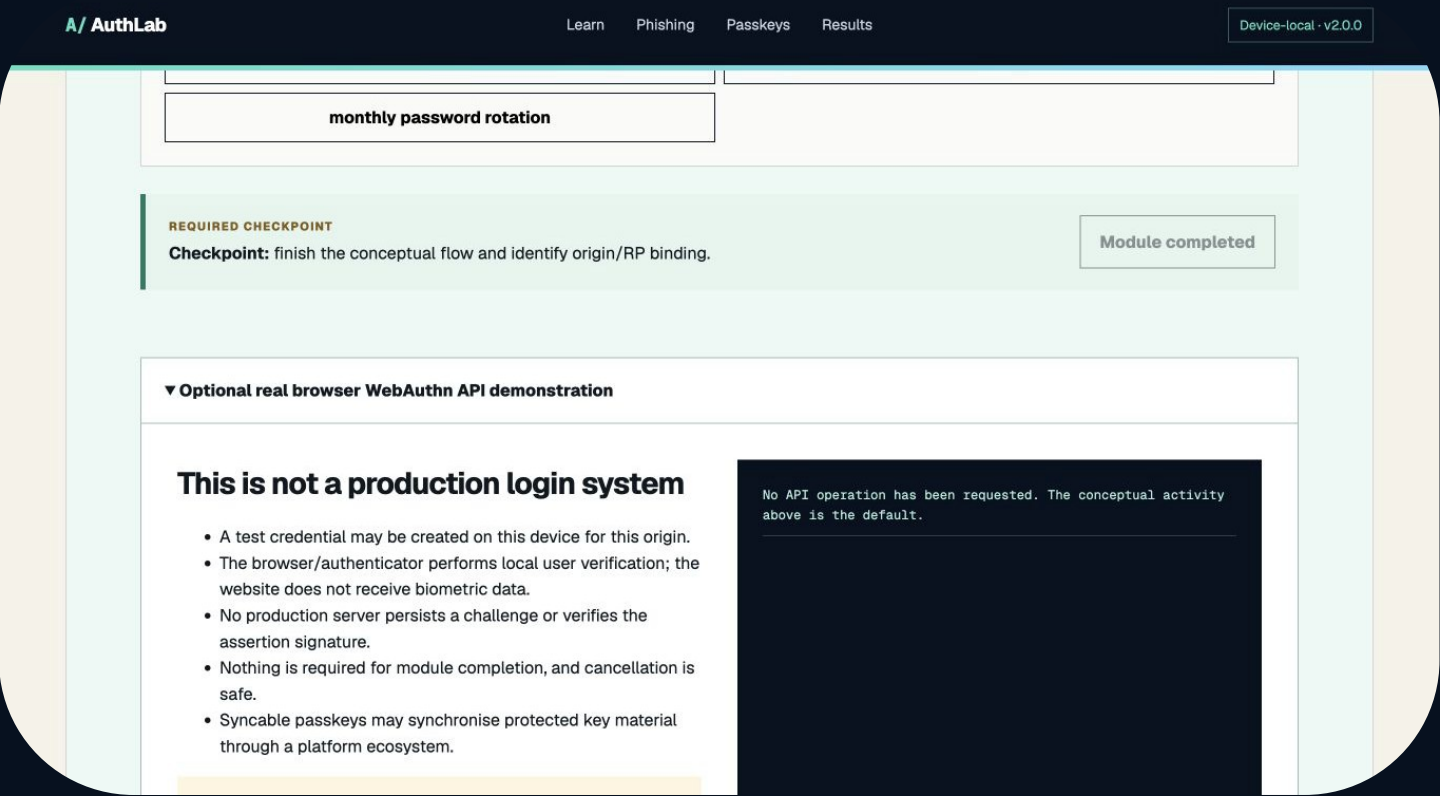
Tests prove function; genuine
participants test learning.

[Website](#) · [learner workbook](#) · [facilitator guide](#) · [report](#) · [90–105 second demo](#)

[Public AuthLab site](#)

Phishing-resistant does not mean invulnerable

RP binding narrows one attack class; it does not secure the whole account lifecycle.



RISK	EXAMPLE	CONTROL
DEVICE	compromise	HARDEN
RECOVERY	weak fallback	MODEL
SERVER	logic error	VERIFY

Precise claim

Passkeys improve phishing resistance under the WebAuthn trust model.

Why can TOTP still be relayed in real time?

Expiry limits time; it does not bind the code to the intended verifier.

A/ AuthLab Learn Passwords Phishing Passkeys Results Device-local · v2.0.0

03 PHISHING AND IMPERSONATION · LO-03

Verifier evidence beats copied pixels

Assume the attacker can build a polished real-time phishing site and relay passwords or OTPs.

PH-01 · FROM
IT Service Desk <support@example.edu>

Security key registration is available

https://accounts.example.edu/security-keys

Legitimate **Phishing**

Correct decision. The registered domain is example.edu and the route is plausible.

PH-02 · FROM
Campus Account Team <urgent@account-notice.example.net>

Your mailbox closes in 20 minutes

https://example.edu.verify-login.example.net/session

Legitimate **Phishing**

Correct decision. The registered domain is example.net; example.edu is only a subdomain label.

ATTACK PATH

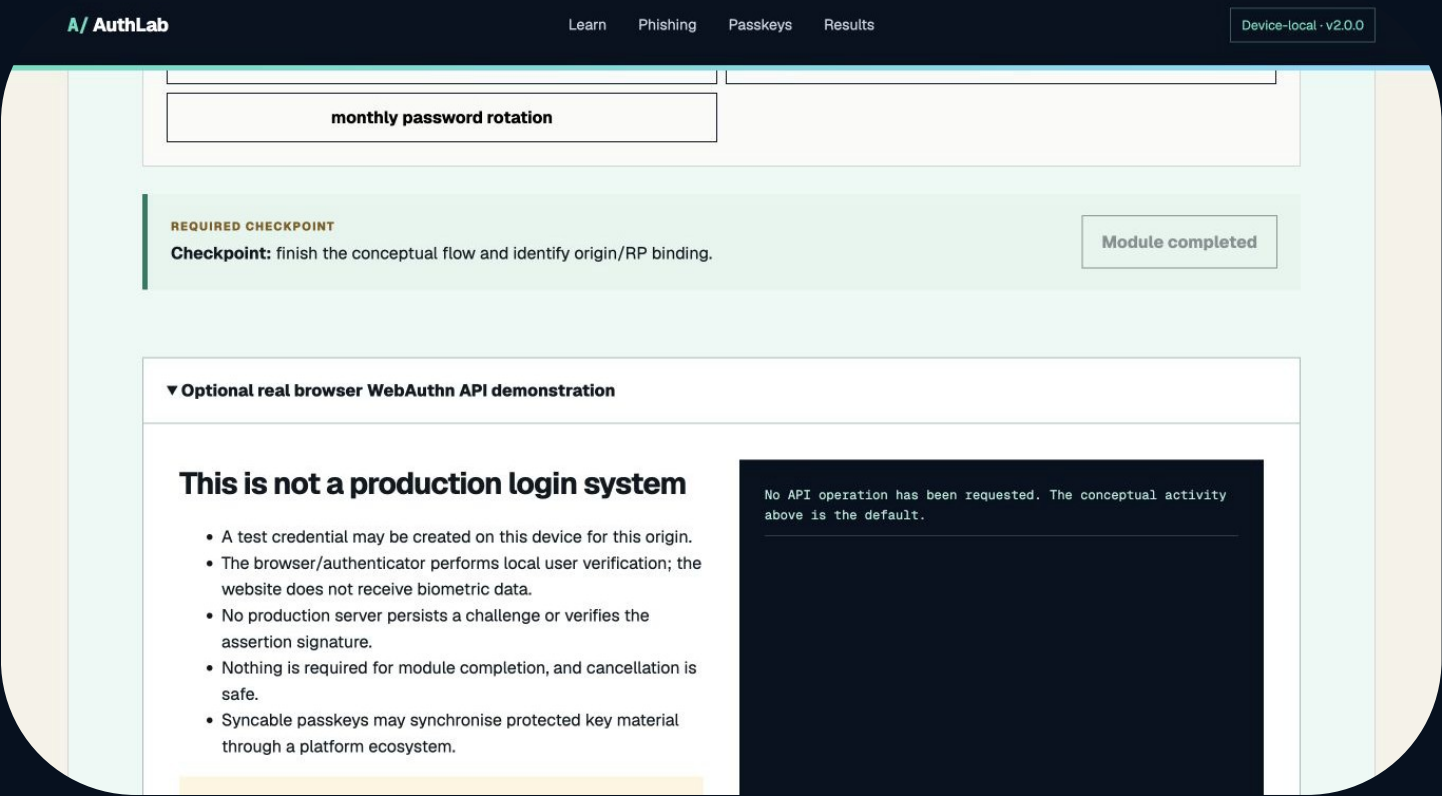
Victim enters code.
Proxy sends it onward.
Real service accepts it.
Attacker receives session.

Key distinction

Short-lived output can resist later replay and still be phished through immediate relay.

The optional browser demo is not a secure login

It observes API boundaries but deliberately omits production server responsibilities.



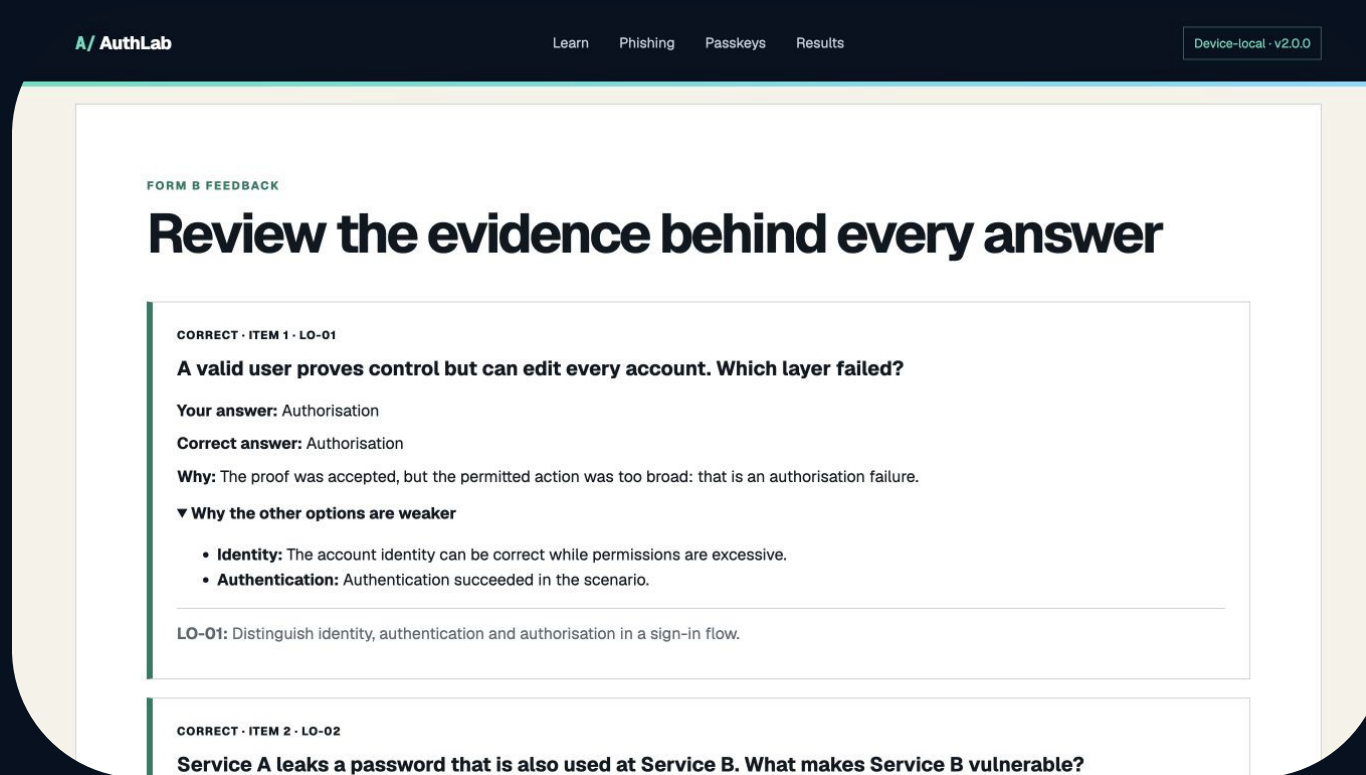
MISSING	REQUIRED	STATUS
CHALLENGE	server state	NONE
CREDENTIAL	account record	NONE
ASSERTION	signature verify	NONE

Demo boundary

Client-only create/get is never described as production authentication.

The export is de-identified, not guaranteed anonymous

Data minimisation reduces risk; outside context can still re-identify a record.



IDENTITY

0

No name, email or zID

TIME

0

No exact timestamps

CONTROL

LOCAL

Learner exports and deletes

The file still needs restricted storage and a retention plan; do not call it fully anonymous.

Parallel forms reduce rehearsal, not every validity threat

Form A hides feedback; Form B explains answers only after submission.

A/ AuthLab Learn Phishing Passkeys Results Device-local - v2.0.0

FORM B FEEDBACK

Review the evidence behind every answer

CORRECT · ITEM 1 · LO-01

A valid user proves control but can edit every account. Which layer failed?

Your answer: Authorisation

Correct answer: Authorisation

Why: The proof was accepted, but the permitted action was too broad: that is an authorisation failure.

▼ Why the other options are weaker

- **Identity:** The account identity can be correct while permissions are excessive.
- **Authentication:** Authentication succeeded in the scenario.

LO-01: Distinguish identity, authentication and authorisation in a sign-in flow.

CORRECT · ITEM 2 · LO-02

Service A leaks a password that is also used at Service B. What makes Service B vulnerable?

FORM A

HIDE

No score or answer reveal

FORM B

SHOW

Rationale + distractors + LO

HUMANS

0

No effectiveness claim

Remaining threats: convenience sample, self-selection, practice effect, no retention test and facilitator influence.

The limitations narrow what the project can claim

Each gap belongs to a different evidence category.

MEASUREMENT

No participants or retention test

Evidence gap

TECHNICAL

No production WebAuthn verifier

System boundary

ACCESS

No screen-reader user study

QA boundary

Rule

Build tests prove implementation; sources support technical claims; only genuine participants support teaching effectiveness.

Future work strengthens evidence, not slogans.

01 Evaluate

Run the consented protocol and report every outcome.

02 Extend

Build a controlled reference RP plus recovery threat model.

03 Test

Add assistive-technology and browser/authenticator coverage.

Next: genuine participant evidence · server verification · accessibility matrix

No invented outcomes